

BÁO CÁO THỰC HÀNH AN TOÀN ỨNG DỤNG WEB

LAB 6

COOKIE POISONING

Từ dữ liệu client-controlled đến server-side authorization

Sinh viên: Lê Minh

MSSV: 21127645

Môi trường: http://127.0.0.1:5006 - dữ liệu giả lập local

Generated from evidence: 2026-07-14T20:26:01.079826+00:00

Chương 1. Giới thiệu

Lab06 minh họa Cookie Poisoning trong một ứng dụng Flask chỉ chạy local. Trọng tâm là ranh giới tin cậy: browser giữ cookie nhưng server chịu trách nhiệm xác thực, quản lý phiên và phân quyền.

Báo cáo được tạo từ source, trace, request, response, cookie, session, audit và log kiểm thử thực. Các số liệu vận hành trong tài liệu không được suy diễn từ cấu hình hay ghi cứng.

Chương 2. Mục tiêu và phạm vi an toàn

Mục tiêu là quan sát dữ liệu cookie, tái hiện lỗi role phía client trong hai mode cố ý dễ bị tấn công, rồi đối chiếu với signing, authenticated encryption và server-side session.

Phạm vi bị giới hạn tại http://127.0.0.1:5006. Lab không truy cập website thật, không kết nối Internet khi runtime, không có proxy, cookie editor tổng quát, XSS, hijacking, replay UI hay công cụ tự động hóa trình duyệt.

Chương 3. Cookie là gì

Cookie là cặp tên-giá trị do server đặt trong response và browser gửi lại theo phạm vi Domain/Path cùng các thuộc tính liên quan. Cookie là cơ chế vận chuyển state, không tự tạo ra niềm tin.

Dữ liệu nhận từ Cookie header phải được kiểm tra giống mọi input khác. Một tên cookie quen thuộc hoặc flag bảo mật không chứng minh nội dung đúng.

Chương 4. Cấu trúc và thuộc tính cookie

Name và Value xác định dữ liệu; Domain và Path giới hạn nơi gửi; HttpOnly hạn chế JavaScript đọc cookie; Secure giới hạn truyền qua HTTPS; SameSite giảm một số request cross-site.

Các flag hỗ trợ giảm bề mặt tấn công nhưng không ký, mã hóa hoặc xác minh role trong payload. Giá trị hiển thị trong báo cáo phải lấy từ response/config evidence thực.

Chương 5. Cookie là dữ liệu không đáng tin cậy

Người dùng kiểm soát browser, storage và request gửi đi. Vì vậy role, is_admin, balance hay permission nằm trong cookie đều có thể bị thay đổi nếu không có cơ chế integrity và policy server-side.

Server phải xác minh danh tính, trạng thái phiên và quyền từ nguồn có thẩm quyền trên mỗi request nhạy cảm.

Chương 6. Cookie Poisoning là gì

Cookie Poisoning là sửa nội dung cookie trước khi gửi lại để làm thay đổi logic ứng dụng. Trong lab, giá trị role=user được đổi thủ công thành role=admin tại đúng origin local.

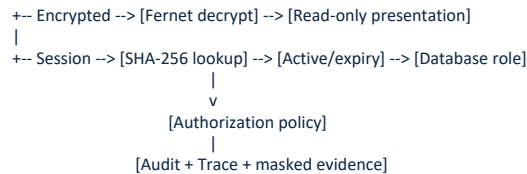
Root cause không phải DevTools mà là quyết định phân quyền dựa trên dữ liệu client-controlled. Tác động minh họa là leo thang đặc quyền trong trang admin giả lập.

Chương 7. Kiến trúc Lab06

Kiến trúc tách route Flask, service cookie/session, authorization, SQLite, audit và trace. Plain/Base64 cố ý tin dữ liệu client; Signed xác minh integrity trước khi dùng payload; Session lấy role từ database.

```
Browser local -> Flask /login: credentials + fixed mode
Flask -> SQLite users: parameterized user lookup
SQLite --> Flask: password hash + current role
Flask -> Browser: Set-Cookie for selected mode
Browser -> Flask protected route: fixed Lab06 cookie
Flask -> Verification/Session service: decode, verify, decrypt, or hash lookup
Verification/Session service -> Authorization: trusted facts only
Authorization -> SQLite: current role lookup for secure modes
Authorization --> Flask: allow/deny + reason
Flask -> Audit/Trace: redacted event + evidence link
Flask --> Browser: response + Inspector + Final Verdict
```

```
[Untrusted Browser Storage]
| Cookie header
v
[Flask Request Boundary] -- Plain/Base64 --> [Vulnerable client-role decision]
|
+-- Signed --> [Verify integrity] --> [Database role]
|
```



Chương 8. Database schema và tài khoản demo

SQLite chứa users, server_sessions, audit_logs, cookie_events và session_events. Mọi truy vấn phải có tham số; database chỉ giữ hash Session ID, không giữ token thô.

Hai tài khoản demo dùng password hash PBKDF2-SHA256 600000 vòng. Password demo chỉ dùng ở form login và không xuất hiện trong evidence.

Database schema

Bảng	Trường chính	Ý nghĩa
users	id, username, display_name, email, password_hash, role, active, timestamps	Role có thẩm quyền
server_sessions	session_token_hash, user_id, expiry, active, revoked_at, rotation_reason	Không lưu raw token
audit_logs	actor, route, mode, cookie status, submitted/database role, decision, reason, trace_id	Dữ liệu đã che
cookie_events	operation, fingerprint, signature/encryption status, decision	Không full cookie
session_events	event_type, old/new fingerprint, reason, trace_id	Rotation/revocation

Tài khoản demo

ID	Username	Display name	Email	Role	Password storage
1	admin_lab	Quản trị Lab	admin@lab.local	admin	PBKDF2-SHA256:600000
10	student	Sinh viên Demo	student@lab.local	user	PBKDF2-SHA256:600000

Chương 9. Plain Cookie vulnerable

Plain mode đặt lab06_username và lab06_role. Route admin cố ý so sánh trực tiếp role trong request.cookies, không kiểm tra integrity và không truy vấn database role.

Trace table - Plain cookie login (evidence/traces/plain_login_student.json)

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	HTTP Request	Receive fixed Lab06 cookie input	request.cookies	{"cookie_names":["lab06_role","lab06_username"]}	{"mode":"plain","route":"/login"}	app.py:request_boundary	observed	Cookie input crosses the browser-to-server trust boundary.
2	Authentication/Authorization	Cookie issuance	response.set_cookie	{"cookie_name":"lab06_role","cookie_present":false}	{"decision":"cookie_issued","mode":"plain"}	app.py:login	cookie_is_sued	The vulnerable model places authorization state in client storage.

Trace table - Plain admin denied (evidence/traces/plain_admin_denied.json)

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	HTTP Request	Receive fixed Lab06 cookie input	request.cookies	{"cookie_names":["lab06_role","lab06_username"]}	{"mode":"plain","route":"/vulnerable/plain/admin"}	app.py:request_boundary	observed	Cookie input crosses the browser-to-server trust boundary.
2	Authentication/Authorization	Client-role authorization	client role comparison	{"cookie_name":"lab06_role","cookie_present":true}	{"decision":"deny","mode":"plain"}	authorization_service.py:authorize_plain_admin	deny	Trusting a mutable cookie role creates Broken Access Control.

Chương 10. Phân tích thay đổi role trong plain cookie

Trạng thái ban đầu role=user dẫn tới deny. Khi người học sửa thủ công thành admin, request sau được allow vì server không phân biệt được giá trị ban đầu và giá trị đã bị sửa.

Bản vá là không dùng role client làm nguồn quyền; thay bằng session opaque và database-backed authorization.

Trace table - Plain cookie modified (evidence/traces/plain_admin_cookie_modified.json)

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	HTTP Request	Receive fixed Lab06 cookie input	request.cookies	{"cookie_names":["lab06_role","lab06_username"]}	{"mode":"plain","route":"/vulnerable/plain/admin"}	app.py:request_boundary	observed	Cookie input crosses the browser-to-server trust boundary.
2	Authentication/Authorization	Client-role authorization	client role comparison	{"cookie_name":"lab06_role","cookie_present":true}	{"decision":"allow","mode":"plain"}	authorization_service.py:authorize_plain_admin	allow	Trusting a mutable cookie role creates Broken Access Control.

Chương 11. Base64 Cookie vulnerable

Base64 mode lưu JSON username/role trong lab06_profile_b64. Server URL-safe Base64 decode, parse JSON rồi cố ý dùng role mà không có chữ ký.

Trace table - Base64 original (evidence/traces/base64_admin_denied.json)

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	HTTP Request	Receive fixed Lab06 cookie input	request.cookies	{"cookie_names":["lab06_profile_b64"]}	{"mode":"base64","route":"/vulnerable/base64/admin"}	app.py:request_boundary	observed	Cookie input crosses the browser-to-server trust boundary.
2	Authentication/Authorization	Decode and authorize	Base64 decode plus client role comparison	{"cookie_name":"lab06_profile_b64","cookie_present":true}	{"decision":"deny","mode":"base64"}	base64_cookie_service.py:authorize_decoded_role	deny	A reversible encoding does not make authorization data trustworthy.

Trace table - Base64 modified (evidence/traces/base64_admin_cookie_modified.json)

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	HTTP Request	Receive fixed Lab06 cookie input	request.cookies	{"cookie_names":["lab06_profile_b64"]}	{"mode":"base64","route":"/vulnerable/base64/admin"}	app.py:request_boundary	observed	Cookie input crosses the browser-to-server trust boundary.
2	Authentication/Authorization	Decode and authorize	Base64 decode plus client role comparison	{"cookie_name":"lab06_profile_b64","cookie_present":true}	{"decision":"allow","mode":"base64"}	base64_cookie_service.py:authorize_decoded_role	allow	A reversible encoding does not make authorization data trustworthy.

Chương 12. Base64 không phải mã hóa

Base64 biến bytes thành ký tự thuận tiện vận chuyển. Bất kỳ ai có chuỗi đều có thể decode, sửa JSON và encode lại; do đó confidentiality và integrity đều không tồn tại.

Chương 13. Signed Cookie

Signed cookie gắn chữ ký HMAC thông qua itsdangerous. Server phải xác minh chữ ký trước khi chấp nhận payload; token thiếu, sai format hoặc bị sửa phải bị từ chối.

Payload signed vẫn có thể đọc được nếu format lộ nội dung. Signing không phải encryption và không thay thế kiểm tra role mới nhất từ database.

Trace table - Signed cookie valid (evidence/traces/signed_cookie_valid.json)

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	HTTP Request	Receive fixed Lab06 cookie input	request.cookies	{"cookie_names":["lab06_signed_profile"]}	{"mode":"signed","route":"/secure/signed/admin"}	app.py:request_boundary	observed	Cookie input crosses the browser-to-server trust boundary.
2	Authentication/Authorization	Verify then authorize	signature verification plus database role lookup	{"cookie_name":"lab06_signed_profile","cookie_present":true}	{"decision":"allow","mode":"signed"}	signed_cookie_service.py:verify_signed_profile	allow	Integrity is verified before payload use; authorization still uses server state.

Chương 14. HMAC và kiểm tra toàn vẹn

HMAC tính mã xác thực từ payload và secret server-side. Sửa payload hoặc signature làm kết quả tính lại không khớp, giúp phát hiện mất integrity và authenticity.

Secret không được đưa vào client, log, trace hay báo cáo. Revocation của signed payload khó hơn server-side session nếu không có state kiểm soát bổ sung.

Trace table - Signed cookie invalid (evidence/traces/signed_cookie_tampered.json)

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	HTTP Request	Receive fixed Lab06 cookie input	request.cookies	{"cookie_names":["lab06_signed_profile"]}	{"mode":"signed","route":"/secure/signed/profile"}	app.py:request_boundary	observed	Cookie input crosses the browser-to-server trust boundary.
2	Authentication/Authorization	Verify then authorize	signature verification plus database role lookup	{"cookie_name":"lab06_signed_profile","cookie_present":true}	{"decision":"invalid","mode":"signed"}	signed_cookie_service.py:verify_signed_profile	invalid	Integrity is verified before payload use; authorization still uses server state.

Chương 15. Encrypted Cookie

Encrypted demo dùng Fernet cho payload read-only gồm user_id, display_name, preference và issued_at. Payload không có role, password hoặc Session ID thật.

Trace table - Encrypted cookie valid (evidence/traces/encrypted_cookie_valid.json)

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	HTTP Request	Receive fixed Lab06 cookie input	request.cookies	{"cookie_names":["]}	{"mode":"encrypted","route":"/secure/encrypted-demo"}	app.py:request_boundary	observed	Cookie input crosses the browser-to-server trust boundary.
2	Authentication/Authorization	Authenticated decryption	Fernet authenticated decryption	{"cookie_name":"lab06_encrypted_profile","cookie_present":false}	{"decision":"read_only_demo","mode":"encrypted"}	encrypted_cookie_service.py:decrypt_demo_profile	read_only_demo	Confidentiality and integrity are demonstrated without payload authorization.

Chương 16. Authenticated Encryption

Authenticated encryption đồng thời che plaintext và xác thực token. Sửa một byte hoặc dùng sai key làm decrypt thất bại trước khi plaintext được sử dụng.

Encryption bảo vệ dữ liệu, nhưng policy vẫn phải quyết định quyền từ nguồn server-side có thể cập nhật và revoke.

Trace table - Encrypted cookie tampered (evidence/traces/encrypted_cookie_tampered.json)

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	HTTP Request	Receive fixed Lab06 cookie input	request.cookies	{"cookie_names":["]}	{"mode":"encrypted","route":"/secure/encrypted-demo"}	app.py:request_boundary	observed	Cookie input crosses the browser-to-server trust boundary.
2	Authentication/Authorization	Authenticated decryption	Fernet authenticated decryption	{"cookie_name":"lab06_encrypted_profile","cookie_present":false}	{"decision":"read_only_demo","mode":"encrypted"}	encrypted_cookie_service.py:decrypt_demo_profile	read_only_demo	Confidentiality and integrity are demonstrated without payload authorization.

Chương 17. Server-side Session

Server-side session đặt một Session ID ngẫu nhiên trong lab06_session. Server hash token, tra record active/unexpired, lấy user và role từ database rồi mới authorize.

Trace table - Server-side student login (evidence/traces/server_session_student_login.json)

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	HTTP Request	Receive fixed Lab06 cookie input	request.cookies	{"cookie_names":["]}	{"mode":"session","route":"/login"}	app.py:request_boundary	observed	Cookie input crosses the browser-to-server trust boundary.
2	Authentication/Authorization	Fixed local flow	bounded workflow	{"cookie_name":"null","cookie_present":false}	{"decision":"session_created","mode":"session"}	app.py:create_app	session_created	Only Lab06 local behavior is recorded.

Chương 18. Session ID ngẫu nhiên

Session ID được sinh bằng secrets.token_urlsafe(32) để có entropy cao và không mang ý nghĩa nghiệp vụ. Cookie không chứa role hoặc user_id.

Database lưu SHA-256 của token để giảm tác động nếu bằng session bị lộ; so khớp được thực hiện bằng cách hash token request.

Chương 19. Session rotation

Rotation sau login tạo token mới và thu hồi token trước đó. Cơ chế này cắt liên kết với định danh phiên cũ và hỗ trợ giảm rủi ro fixation.

Trace table - Session rotation (evidence/traces/server_session_rotated.json)

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	HTTP Request	Receive fixed Lab06 cookie input	request.cookies	{"cookie_names":["lab06_session"]}	{"mode":"session","route":"/login"}	app.py:request_boundary	observed	Cookie input crosses the browser-to-server trust boundary.
2	Authentication/Authorization	Fixed local flow	bounded workflow	{"cookie_name":"null","cookie_present":false}	{"decision":"session_created","mode":"session"}	app.py:create_app	session_created	Only Lab06 local behavior is recorded.

Chương 20. Logout và server-side invalidation

Logout phải đổi state server thành inactive/revoked và đồng thời expire cookie browser. Chỉ xóa cookie client sẽ để token cũ còn hợp lệ ở server.

Trace table - Logout invalidation (evidence/traces/server_session_logout.json)

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	HTTP Request	Receive fixed Lab06 cookie input	request.cookies	{"cookie_names":["lab06_session"]}	{"mode":"server_session","route":"/secure/session/logout"}	app.py:request_boundary	observed	Cookie input crosses the browser-to-server trust boundary.
2	Authentication/Authorization	Server-side authorization	SHA-256 lookup plus database policy	{"cookie_name":"lab06_session","cookie_present":true}	{"decision":"logout","mode":"server_session"}	server_session_service.py:resolve_session	logout	Revocation, expiry, rotation, and current role remain server-authoritative.

Trace table - Old session rejection (evidence/traces/old_session_rejection.json)

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	HTTP Request	Receive fixed Lab06 cookie input	request.cookies	{"cookie_names":["lab06_session"]}	{"mode":"server_session","route":"/secure/session/profile"}	app.py:request_boundary	observed	Cookie input crosses the browser-to-server trust boundary.
2	Authentication/Authorization	Server-side authorization	SHA-256 lookup plus database policy	{"cookie_name":"lab06_session","cookie_present":true}	{"decision":"deny","mode":"server_session"}	server_session_service.py:resolve_session	deny	Revocation, expiry, rotation, and current role remain server-authoritative.

Chương 21. Server-side authorization

Authorization Inspector phải thể hiện subject, action, policy, nguồn role, database role, decision và reason. Student bị deny; admin chỉ được allow sau database lookup.

Thay đổi role trong database phải có hiệu lực ở request kế tiếp mà không cần phát hành cookie role mới.

Trace table - Student admin denied (evidence/traces/server_session_student_admin_denied.json)

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	HTTP Request	Receive fixed Lab06 cookie input	request.cookies	{"cookie_names":["lab06_session"]}	{"mode":"server_session","route":"/secure/session/admin"}	app.py:request_boundary	observed	Cookie input crosses the browser-to-server trust boundary.
2	Authentication/Authorization	Server-side authorization	SHA-256 lookup plus database policy	{"cookie_name":"lab06_session","cookie_present":true}	{"decision":"deny","mode":"server_session"}	server_session_service.py:resolve_session	deny	Revocation, expiry, rotation, and current role remain server-authoritative.

Trace table - Admin allowed (evidence/traces/server_session_admin_allowed.json)

STT	Layer	Action	Technique	Input	Output	Code reference	Status	Security meaning
1	HTTP Request	Receive fixed Lab06 cookie input	request.cookies	{"cookie_names":["lab06_session"]}	{"mode":"server_session","route":"/secure/session/admin"}	app.py:request_boundary	observed	Cookie input crosses the browser-to-server trust boundary.
2	Authentication/Authorization	Server-side authorization	SHA-256 lookup plus database policy	{"cookie_name":"lab06_session","cookie_present":true}	{"decision":"allow","mode":"server_session"}	server_session_service.py:resolve_session	allow	Revocation, expiry, rotation, and current role remain server-authoritative.

Chương 22. Cookie flags

HttpOnly giảm khả năng script đọc cookie; Secure yêu cầu HTTPS; SameSite giảm một số CSRF. Với HTTP local, Secure phải phản ánh cấu hình thực thay vì được ghi đặt giả.

Chương 23. Cookie Poisoning và Session Hijacking

Cookie Poisoning thay đổi nội dung để đổi logic. Session Hijacking chiếm một phiên hợp lệ, thường bằng cách lấy Session ID. Hai hành vi có mục tiêu và biện pháp kiểm soát khác nhau.

Chương 24. Cookie Poisoning và Session Fixation

Session Fixation ép nạn nhân dùng Session ID đã biết rồi chờ đăng nhập. Cookie Poisoning sửa dữ liệu cookie để lừa logic. Rotation sau login là kiểm soát quan trọng chống fixation.

Chương 25. Cookie Stealing và XSS

Cookie Stealing qua XSS lấy cookie hiện có; HttpOnly có thể giảm khả năng script đọc token nhưng không sửa lỗi XSS và không ngăn người dùng sửa cookie của chính họ bằng DevTools.

Chương 26. So sánh năm mô hình

Ma trận dưới đây so sánh nơi lưu state, khả năng đọc/sửa, integrity, confidentiality, revocation và nguồn authorization của năm mô hình.

Ma trận so sánh năm mô hình

Tiêu chí	Plain	Base64	Signed	Encrypted	Server session
Dữ liệu nằm ở đâu	Client	Client	Client	Client token	State server
Người dùng đọc được	Có	Có sau decode	Thường có	Không nếu key an toàn	Chỉ opaque ID
Người dùng sửa được	Có	Có	Có nhưng bị phát hiện	Có nhưng decrypt fail	Token không mang role
Server phát hiện sửa	Không	Không	Có	Có	Lookup/token state
Confidentiality	Không	Không	Không	Có	State không ở client
Integrity	Không	Không	Có	Có	Opaque + server state
Revocation	Kém	Kém	Khó nếu stateless	Khó nếu stateless	Tức thời server-side
Role ở client	Có	Có	Payload demo có	Không dùng	Không
Authorization source	Cookie role	Decoded role	Database sau verify	Không authorize	Database
Dữ liệu nhạy cảm	Không phù hợp	Không phù hợp	Không che nội dung	Có thể nếu cần	Phù hợp hơn
Rủi ro còn lại	Poisoning	Poisoning	Replay/stale role	Key/replay/stale state	Token theft/CSRF

Chương 27. Code Comparison

Code Comparison được trích trực tiếp từ marker trong source hiện hành. Báo cáo không sử dụng snippet được viết lại độc lập với implementation.

Plain: client role ↔ Signed: verify before use

Plain: client role - authorization_service.py	Signed: verify before use - signed_cookie_service.py
<pre>def authorize_plain_admin(identity: PlainCookieIdentity) -> AuthorizationDecision: allowed = identity.username_present and identity.role_present and identity.role == "admin" return AuthorizationDecision(allowed=allowed, subject=identity.username, action="view_admin", resource="plain_admin_page", authentication_source="client_cookie", submitted_role=identity.role, database_role=None, policy="trust client-controlled lab06_role cookie", reason="client_cookie_role_admin" if allowed else "client_cookie_role_not_admin", database_role_checked=False,) #</pre>	<pre>def verify_signed_profile(value: str None, config: LabConfig Mapping[str, Any] Any) -> SignedVerificationResult: if not value: return SignedVerificationResult(False, None, "missing", "missing_cookie", False) try: # itsdangerous verifies the signature before returning deserialized data. data = create_serializer(config).loads(value) except BadData: return SignedVerificationResult(False, None, "invalid", "signature_rejected", False) if not isinstance(data, dict) or set(data) != { "user_id", "username", "role", "issued_at", "purpose" }: return SignedVerificationResult(False, None, "valid", "invalid_payload_shape", True) if (not isinstance(data["user_id"], int) or isinstance(data["user_id"], bool) or data["user_id"] <= 0 or not isinstance(data["username"], str) or not 1 <= len(data["username"]) <= 64 or data["role"] not in ("user", "admin") or not isinstance(data["issued_at"], str) or data["purpose"] != SIGNED_PURPOSE): return SignedVerificationResult(False, None, "valid", "invalid_payload_values", True) profile = SignedProfile(user_id=data["user_id"], username=data["username"], role=data["role"], issued_at=data["issued_at"], purpose=data["purpose"],) return SignedVerificationResult(True, profile, "valid", "signature_verified", True) #</pre>

Base64: decoded role ↔ Server session: database role

Base64: decoded role - base64_cookie_service.py	Server session: database role - server_session_service.py
<pre>def authorize_decoded_role(result: Base64DecodeResult) -> bool: return bool(result.valid and result.profile and result.profile.role == "admin") #</pre>	<pre>def resolve_session(conn: sqlite3.Connection, raw_token: str None, now: datetime) -> SessionResolution: if not raw_token: return SessionResolution(False, "missing_session_cookie") token_hash = hash_session_token(raw_token) token_fingerprint = fingerprint_session_token(raw_token) row = conn.execute("SELECT s.id, s.user_id, s.created_at, s.expires_at, s.last_seen_at, s.active, " "u.username, u.role, u.active AS user_active FROM server_sessions AS s " "JOIN users AS u ON u.id = s.user_id WHERE s.session_token_hash = ?", (token_hash,),).fetchone() if row is None: return SessionResolution(False, "unknown_session", token_fingerprint=token_fingerprint) common = dict(session_id=int(row["id"]), token_fingerprint=token_fingerprint, user_id=int(row["user_id"]), username=str(row["username"]), database_role=str(row["role"]), active=bool(row["active"]), created_at=str(row["created_at"]), expires_at=str(row["expires_at"]), last_seen_at=str(row["last_seen_at"]),) if not bool(row["active"]): return SessionResolution(False, "inactive_session", **common) current = _aware(now) if _parse_time(str(row["expires_at"])) <= current: with transaction(conn, immediate=True): conn.execute("UPDATE server_sessions SET active = 0, revoked_at = ?, rotation_reason = ? WHERE id = " "?", (isoformat_utc(current), "expired", int(row["id"])),) common["active"] = False return SessionReso</pre>

Session rotation ↔ Logout invalidation

Session rotation - server_session_service.py	Logout invalidation - server_session_service.py
<pre>def rotate_session(conn: sqlite3.Connection, *, user_id: int, previous_raw_token: str None, now: datetime, ttl: timedelta, trace_id: str, reason: str = "login",) -> SessionIssue: current = _aware(now) created_at = isoformat_utc(current) expires_at = isoformat_utc(current + ttl) raw_token = generate_session_token() token_hash = hash_session_token(raw_token) new_fingerprint = fingerprint_session_token(raw_token) old_fingerprint = fingerprint_session_token(previous_raw_token) if previous_raw_token else None with transaction(conn, immediate=True): revoked = 0 if previous_raw_token: revoked = conn.execute("UPDATE server_sessions SET active = 0, revoked_at = ?, rotation_reason = ? " "WHERE session_token_hash = ? AND active = 1", (created_at, reason, hash_session_token(previous_raw_token)),).rowcount conn.execute("INSERT INTO server_sessions (session_token_hash, user_id, created_at, expires_at, " "last_seen_at, active, revoked_at, rotation_reason) VALUES (?, ?, ?, ?, 1, NULL, ?)", (token_hash, user_id, created_at, expires_at, created_at, reason),) conn.execute("INSERT INTO session_events (timestamp, user_id, event_type, old_session_fingerprint, " "new_session_fingerprint, reason, trace_id) VALUES (?, ?, ?, ?, ?, ?, ?)", (created_at, user_id, "server_session_rotated" if revoked else "server_ses</pre>	<pre>def revoke_session(conn: sqlite3.Connection, *, raw_token: str None, now: datetime, reason: str, trace_id: str,) -> bool: if not raw_token: return False timestamp = isoformat_utc(_aware(now)) token_hash = hash_session_token(raw_token) token_fingerprint = fingerprint_session_token(raw_token) with transaction(conn, immediate=True): row = conn.execute("SELECT id, user_id FROM server_sessions WHERE session_token_hash = ? AND active = " "1", (token_hash,),).fetchone() if row is None: return False conn.execute("UPDATE server_sessions SET active = 0, revoked_at = ?, rotation_reason = ? WHERE id = " "?", (timestamp, reason, int(row["id"])),) conn.execute("INSERT INTO session_events (timestamp, user_id, event_type, old_session_fingerprint, " "new_session_fingerprint, reason, trace_id) VALUES (?, ?, ?, ?, NULL, ?, ?)", (timestamp, int(row["user_id"]), "logout_invalidated_session", token_fingerprint, reason, trace_id),) return True #</pre>

Authenticated decryption ↔ Cookie flags

Authenticated decryption - encrypted_cookie_service.py	Cookie flags - config.py
<pre>def decrypt_demo_profile(token: str None, config: LabConfig Mapping[str, Any] Any) -> EncryptionResult: if not token: return EncryptionResult(False, None, "missing", True, True, "missing_cookie") try: # Fernet authenticates the token before returning plaintext. plaintext = create_fernet(config).decrypt(token.encode("ascii")) data = json.loads(plaintext.decode("utf-8")) except (InvalidToken, UnicodeEncodeError, UnicodeDecodeError, json.JSONDecodeError): return EncryptionResult(False, None, "invalid", True, True, "authenticated_decryption_failed") if not isinstance(data, dict) or set(data) != { "user_id", "display_name", "preference", "issued_at" }: return EncryptionResult(False, None, "valid", True, True, "invalid_payload_shape") if (not isinstance(data["user_id"], int) or isinstance(data["user_id"], bool) or data["user_id"] <= 0 or not isinstance(data["display_name"], str) or not isinstance(data["preference"], str) or not isinstance(data["issued_at"], str)): return EncryptionResult(False, None, "valid", True, True, "invalid_payload_values") profile = EncryptedProfile(user_id=data["user_id"], display_name=data["display_name"][:100], preference=data["preference"][:100], issued_at=data["issued_at"],) return EncryptionResult(True, profile, "valid", True, True, "authenticated_decryption_succeeded") #</pre>	<pre>def cookie_options(config: LabConfig Mapping[str, Any] Any, *, httponly: bool, max_age: int None = None,) -> dict[str, object]: options: dict[str, object] = { "path": "/", "secure": bool(_config_value(config, "COOKIE_SECURE")), "httponly": httponly, "samesite": "Lax", } if max_age is not None: options["max_age"] = max_age return options #</pre>

Chương 28. Audit logging

Audit ghi actor, action, route, mode, trạng thái cookie, role submitted/database, decision, reason và trace ID. Log chỉ chứa giá trị đã mask hoặc fingerprint.

Audit events từ evidence thật

Timestamp	Mode	Action	Route	Decision	Reason	Trace ID
2026-07-14T20:23:00.764159Z	plain	plain_cookie_issued	/login	allow	fixed_plain_demo	14a30b55a322a9de7a7bebe9
2026-07-14T20:23:00.858351Z	plain	plain_admin_denied	/vulnerable/plain/admin	deny	client_cookie_role_used	6d32991ccec7a0329ab3718
2026-07-14T20:23:00.878234Z	plain	plain_cookie_role_change_d_observed	/vulnerable/plain/admin	allow	client_cookie_role_used	08e2634f3f3323a84e9d520
2026-07-14T20:23:01.442563Z	base64	base64_cookie_issued	/login	allow	fixed_demo_profile	3c2d0912a00e73c8c5e1806e
2026-07-14T20:23:01.466680Z	base64	base64_decode_success	/vulnerable/base64/admin	deny	decoded_role_used_without_signature	087cb77f64d1a5b2069a9221
2026-07-14T20:23:01.490390Z	base64	base64_admin_allowed_from_cookie	/vulnerable/base64/admin	allow	decoded_role_used_without_signature	cf8e8fa94d2c8a87cfdb9e9e1
2026-07-14T20:23:02.032566Z	signed	signed_cookie_issued	/login	allow	signed_profile_created	7907fb79eff09cbadd3d32a4
2026-07-14T20:23:02.049669Z	signed	signed_cookie_valid	/secure/signed/admin	allow	signature_verified_then_database_role_checked	78365904d428593a977fb9ad
2026-07-14T20:23:02.066313Z	signed	signed_cookie_invalid	/secure/signed/profile	deny	signature_rejected	636fa7a587223f83be5994f7
2026-07-14T20:23:02.088282Z	encrypted	encrypted_demo_generated	/secure/encrypted-demo	not_used	fernet_read_only_demo	a122a3d98992547bf27a7afc
2026-07-14T20:23:02.638167Z	server_session	server_session_created	/login	allow	login_rotation	a7cfecd1bf20d1eae8510c45
2026-07-14T20:23:02.663920Z	server_session	authorization_denied	/secure/session/admin	deny	session_valid	40f58cf768a51ed2ac0cabd2
2026-07-14T20:23:03.238364Z	server_session	server_session_rotated	/login	allow	login_rotation	203b442fe636c0187d871560
2026-07-14T20:23:03.248494Z	server_session	server_session_invalid	/secure/session/profile	deny	inactive_session	7ea89c7bb70d9ed00290915d
2026-07-14T20:23:03.269923Z	server_session	logout_invalidated_session	/secure/session/logout	allow	server_side_record_revoked	0e4839a53210b3e11b407f8a
2026-07-14T20:23:03.846841Z	server_session	server_session_created	/login	allow	login_rotation	f1214dad7574d2118202e69
2026-07-14T20:23:03.883279Z	server_session	authorization_allowed	/secure/session/admin	allow	current_database_role_admin	959504f05030b41ef0babf76

Chương 29. Kết quả kiểm thử

Kết quả chương này được parse từ evidence/logs/pytest.txt. Báo cáo chỉ được tạo khi có ít nhất 80 test pass và không có failure/error.

Pytest summary parse từ log thật

Passed	Failed	Errors	Skipped	Nguồn
183	0	0	0	evidence/logs/pytest.txt

Chương 30. Coverage

Coverage được parse theo từng module lỗi từ evidence/logs/coverage.txt. Mọi module bắt buộc phải đạt tối thiểu 90%; không dùng total để che module thiếu.

Coverage module lỗi

Module	Coverage	Gate
database.py	100%	Đạt
auth_service.py	100%	Đạt
cookie_service.py	100%	Đạt
base64_cookie_service.py	98%	Đạt
signed_cookie_service.py	91%	Đạt
encrypted_cookie_service.py	93%	Đạt
server_session_service.py	96%	Đạt
authorization_service.py	100%	Đạt
audit_service.py	100%	Đạt
trace_service.py	98%	Đạt
TOTAL	97%	Thông tin tham khảo

Chương 31. Runtime smoke test

Runtime smoke phải có marker thành công rõ ràng sau khi app thật được khởi động, health check và các flow local cố định đã chạy. Log mơ hồ hoặc chứa failure làm generator dừng.

Runtime smoke summary parse từ log thật

Status	Success marker	Nguồn
passed	SMOKE_TEST_PASSED	evidence/logs/runtime_smoke.txt

Chương 32. Mức độ ảnh hưởng

Plain/Base64 có thể dẫn tới broken access control và leo thang đặc quyền. Signed/encrypted giảm một số rủi ro payload nhưng vẫn còn rủi ro key management, replay và state stale nếu dùng sai.

Chương 33. Biện pháp phòng chống

Biện pháp chính: không lưu quyền động ở client; dùng opaque session; hash token server-side; rotate; revoke khi logout; kiểm tra role từ database; ký/mã hóa đúng mục đích; giới hạn log và áp dụng cookie flags.

Chương 34. Bài học rút ra

Bài học trung tâm là phân biệt vận chuyển state với nguồn thẩm quyền. Encoding, signing, encryption, flags và session giải quyết các thuộc tính bảo mật khác nhau; không một kỹ thuật đơn lẻ thay thế authorization.

Câu 1. Vì sao cookie là dữ liệu không đáng tin cậy?

Cookie nằm trong browser do người dùng kiểm soát và có thể bị sửa trước khi gửi. Server phải coi nó là input không tin cậy.

Câu 2. Cookie Poisoning khác Session Hijacking như thế nào?

Poisoning sửa nội dung để đổi logic; hijacking chiếm một phiên hợp lệ, thường bằng Session ID bị lộ.

Câu 3. Base64 có phải mã hóa không?

Không. Base64 là encoding có thể đảo ngược công khai, không có key, confidentiality hoặc integrity.

Câu 4. Signed cookie giải quyết vấn đề gì?

Nó phát hiện sửa đổi và xác thực nguồn tạo payload khi secret được bảo vệ.

Câu 5. Vì sao server-side authorization vẫn bắt buộc?

Quyền có thể thay đổi hoặc bị thu hồi; server phải kiểm tra policy và nguồn role có thẩm quyền trên mỗi request.

Câu 6. Signed cookie khác encrypted cookie thế nào?

Signing bảo vệ integrity/authenticity nhưng thường không che nội dung; encryption che nội dung, và Fernet còn xác thực integrity.

Câu 7. Vì sao mã hóa không thay thế kiểm tra quyền?

Decrypt thành công chỉ chứng minh token hợp lệ theo key, không chứng minh subject được phép thực hiện action hiện tại.

Câu 8. Vì sao không nên lưu role, balance hoặc is_admin trong cookie?

Đó là state nhạy cảm và động; nếu client sửa được hoặc dữ liệu stale, quyết định nghiệp vụ bị sai.

Câu 9. HttpOnly giải quyết rủi ro gì?

Nó hạn chế JavaScript đọc cookie và giảm một phần tác động đánh cắp token qua XSS.

Câu 10. Vì sao HttpOnly không ngăn sửa cookie bằng DevTools?

HttpOnly là ràng buộc với script, không tước quyền quản lý storage của người dùng/browser.

Câu 11. Secure flag giải quyết rủi ro gì?

Nó yêu cầu browser chỉ gửi cookie qua HTTPS, giảm lộ token trên kênh HTTP.

Câu 12. SameSite giải quyết rủi ro gì?

Nó hạn chế gửi cookie trong một số ngữ cảnh cross-site và hỗ trợ giảm CSRF.

Câu 13. Vì sao cookie flags không kiểm tra tính toàn vẹn nội dung?

Flags điều khiển cách browser lưu/gửi cookie; chúng không tính MAC hoặc xác minh payload.

Câu 14. Session ID ngẫu nhiên hoạt động ra sao?

Browser giữ token entropy cao; server dùng token để tìm state phiên, còn dữ liệu user/role nằm server-side.

Câu 15. Vì sao chỉ lưu hash Session ID tốt hơn token thô?

Nếu database bị đọc, hash không thể dùng trực tiếp làm cookie để truy cập phiên.

Câu 16. Vì sao phải rotate session sau login?

Rotation vô hiệu định danh trước xác thực và giảm nguy cơ fixation hoặc reuse token cũ.

Câu 17. Vì sao logout phải hủy session phía server?

Nếu chỉ xóa cookie, bản sao token cũ vẫn có thể được server chấp nhận đến khi hết hạn.

Câu 18. Vì sao signed cookie khó revoke hơn server-side session?

Token tự chứa state thường hợp lệ đến khi hết hạn nếu server không giữ deny-list/version; session record có thể revoke tức thời.

Câu 19. Cookie Poisoning khác Parameter Tampering thế nào?

Cookie Poisoning là tampering trên cookie state; Parameter Tampering rộng hơn và có thể nhắm query, form, path hoặc JSON body.

Câu 20. XSS ảnh hưởng tới cookie ra sao?

XSS có thể thực hiện action trong origin và đọc cookie không HttpOnly; HttpOnly giảm đọc token nhưng không loại bỏ XSS.

Câu 21. Session Fixation khác Cookie Poisoning thế nào?

Fixation ép dùng Session ID biết trước; Poisoning sửa dữ liệu cookie để thay đổi hành vi server.

Câu 22. generate_report.py bảo đảm tính trung thực thế nào?

Script dừng khi thiếu evidence/log, parse kết quả thật, yêu cầu 15 trace, kiểm output trước atomic replace và không thêm ảnh giả hoặc khung ảnh trống.

Chương 35. Kết luận

Lab06 chứng minh lỗi phát sinh khi server trao niềm tin cho role phía client và cách chuyển niềm tin về server-side state. Kết luận vận hành chỉ dựa trên evidence và log thực đã kiểm tra.

Phụ lục A. Trace JSON

Evidence inventory

Family	File	Bytes	SHA-256
traces	evidence/traces/admin_allowed.json	2453	7835467569c6eff1...
traces	evidence/traces/base64_admin_cookie_modified.json	1996	8d075b4a9b67b5b3...
traces	evidence/traces/base64_admin_denied.json	1990	b733b5cc095a73a2...
traces	evidence/traces/base64_cookie_login.json	1578	72497e199c2d10e2...
traces	evidence/traces/base64_login_student.json	1578	72497e199c2d10e2...
traces	evidence/traces/base64_modified.json	1996	8d075b4a9b67b5b3...
traces	evidence/traces/base64_original.json	1990	b733b5cc095a73a2...
traces	evidence/traces/encrypted_cookie_tampered.json	2114	5f85a854bfa7389e...
traces	evidence/traces/encrypted_cookie_valid.json	2114	5f85a854bfa7389e...
traces	evidence/traces/encrypted_cookie_valid_and_tampered.json	2114	5f85a854bfa7389e...
traces	evidence/traces/logout_invalidation.json	1667	a12e46fdf0c313af...
traces	evidence/traces/old_session_rejected.json	2294	2b7b24cccc67f0b4...
traces	evidence/traces/old_session_rejection.json	2294	2b7b24cccc67f0b4...
traces	evidence/traces/plain_admin_cookie_modified.json	1632	1485de582dbf3fab...
traces	evidence/traces/plain_admin_denied.json	1629	21ae9723a8c022b1...
traces	evidence/traces/plain_cookie_login.json	1501	3d22e749fac4e3a4...
traces	evidence/traces/plain_cookie_modified.json	1632	1485de582dbf3fab...
traces	evidence/traces/plain_login_student.json	1501	3d22e749fac4e3a4...
traces	evidence/traces/server_session_admin_allowed.json	2453	7835467569c6eff1...
traces	evidence/traces/server_session_admin_login.json	1482	b7521583cb1eb694...
traces	evidence/traces/server_session_logout.json	1667	a12e46fdf0c313af...
traces	evidence/traces/server_session_rotated.json	1519	83a7ca73de3fb0e5...
traces	evidence/traces/server_session_student_admin_denied.json	2431	92ffe72710a7f68d...
traces	evidence/traces/server_session_student_login.json	1482	dd188e263e1b19c0...
traces	evidence/traces/session_rotation.json	1519	83a7ca73de3fb0e5...
traces	evidence/traces/signed_cookie_invalid.json	1888	0df1d7b0acfb8e5f...
traces	evidence/traces/signed_cookie_login.json	1554	9080015e24ed9bf1...
traces	evidence/traces/signed_cookie_tampered.json	1888	0df1d7b0acfb8e5f...
traces	evidence/traces/signed_cookie_valid.json	2347	0998fd9ad0103297...
traces	evidence/traces/student_admin_denied.json	2431	92ffe72710a7f68d...

Trích đoạn evidence thật đã mask

Family	File	Trích đoạn
traces	evidence/traces/admin_allowed.json	{"decision": "allow", "inspectors": {"authorization": {"action": "view_admin", "allowed": true, "authentication_source": "server_session", "database_role": "admin", "database_role_checked": true, "policy": "active server session plus current database role must equal admin", "reason": "current_database_role_admin", "resource": "server_session_admin_page", "subject": "admin_lab", "submitted_role": null}, "session": {"cookie_name": "lab06_session", "database_role": [rút gọn]}}
traces	evidence/traces/base64_admin_cookie_modified.json	{"decision": "allow", "inspectors": {"base64": {"algorithm": "URL-safe Base64", "authorization_result": "allow", "confidentiality": false, "decoded_json": {"username": "student", "role": "admin"}, "integrity": false, "parse_result": "decoded_without_integrity_check", "role_extracted": "admin"}, "mode": "base64", "route": "/vulnerable/base64/admin", "status": "completed", "steps": {"code_reference": "app.py:request_boundary", "description": "Flask reads...[rút gọn]}}
traces	evidence/traces/base64_admin_denied.json	{"decision": "deny", "inspectors": {"base64": {"algorithm": "URL-safe Base64", "authorization_result": "deny", "confidentiality": false, "decoded_json": {"username": "student", "role": "user"}, "integrity": false, "parse_result": "decoded_without_integrity_check", "role_extracted": "user"}, "mode": "base64", "route": "/vulnerable/base64/admin", "status": "completed", "steps": {"code_reference": "app.py:request_boundary", "description": "Flask reads onl...[rút gọn]}}
traces	evidence/traces/base64_cookie_login.json	{"decision": "cookie_issued", "mode": "base64", "route": "/login", "status": "completed", "steps": {"code_reference": "app.py:request_boundary", "description": "Flask reads only the cookies attached to this local request", "input_data": {"cookie_names": []}, "layer": "HTTP Request", "output_data": {"mode": "base64", "route": "/login", "security_meaning": "Cookie input crosses the browser-to-server trust boundary.", "status": "observed", "step_number": 1, "tec...[rút gọn]}}
traces	evidence/traces/base64_login_student.json	{"decision": "cookie_issued", "mode": "base64", "route": "/login", "status": "completed", "steps": {"code_reference": "app.py:request_boundary", "description": "Flask reads only the cookies attached to this local request", "input_data": {"cookie_names": []}, "layer": "HTTP Request", "output_data": {"mode": "base64", "route": "/login", "security_meaning": "Cookie input crosses the browser-to-server trust boundary.", "status": "observed", "step_number": 1, "tec...[rút gọn]}}
traces	evidence/traces/base64_modified.json	{"decision": "allow", "inspectors": {"base64": {"algorithm": "URL-safe Base64", "authorization_result": "allow", "confidentiality": false, "decoded_json": {"username": "student", "role": "admin"}, "integrity": false, "parse_result": "decoded_without_integrity_check", "role_extracted": "admin"}, "mode": "base64", "route": "/vulnerable/base64/admin", "status": "completed", "steps": {"code_reference": "app.py:request_boundary", "description": "Flask reads...[rút gọn]}}
traces	evidence/traces/base64_original.json	{"decision": "deny", "inspectors": {"base64": {"algorithm": "URL-safe Base64", "authorization_result": "deny", "confidentiality": false, "decoded_json": {"username": "student", "role": "user"}, "integrity": false, "parse_result": "decoded_without_integrity_check", "role_extracted": "user"}, "mode": "base64", "route": "/vulnerable/base64/admin", "status": "completed", "steps": {"code_reference": "app.py:request_boundary", "description": "Flask reads onl...[rút gọn]}}
traces	evidence/traces/encrypted_cookie_tampered.json	{"decision": "read_only_demo", "inspectors": {"encryption": {"algorithm": "Fernet authenticated encryption", "authorization_used": false, "confidentiality": true, "decrypt_result": "authenticated_decryption_succeeded", "integrity": true, "key_location": "server environment only", "masked_token": "[REDACTED]", "tamper_detection_result": "authenticated_decryption_failed", "token_fingerprint": "30bf687a00c2"}, "mode": "encrypted", "route": "/secure/encrypted-d...[rút gọn]}}
traces	evidence/traces/encrypted_cookie_valid.json	{"decision": "read_only_demo", "inspectors": {"encryption": {"algorithm": "Fernet authenticated encryption", "authorization_used": false, "confidentiality": true, "decrypt_result": "authenticated_decryption_succeeded", "integrity": true, "key_location": "server environment only", "masked_token": "[REDACTED]", "tamper_detection_result": "authenticated_decryption_failed", "token_fingerprint": "30bf687a00c2"}, "mode": "encrypted", "route": "/secure/encrypted-d...[rút gọn]}}
traces	evidence/traces/encrypted_cookie_valid_and_tampered.json	{"decision": "read_only_demo", "inspectors": {"encryption": {"algorithm": "Fernet authenticated encryption", "authorization_used": false, "confidentiality": true, "decrypt_result": "authenticated_decryption_succeeded", "integrity": true, "key_location": "server environment only", "masked_token": "[REDACTED]", "tamper_detection_result": "authenticated_decryption_failed", "token_fingerprint": "30bf687a00c2"}, "mode": "encrypted", "route": "/secure/encrypted-d...[rút gọn]}}
traces	evidence/traces/logout_invalidation.json	{"decision": "logout", "mode": "server_session", "route": "/secure/session/logout", "status": "completed", "steps": {"code_reference": "app.py:request_boundary", "description": "Flask reads only the cookies attached to this local request", "input_data": {"cookie_names": ["lab06_session"]}, "layer": "HTTP Request", "output_data": {"mode": "server_session", "route": "/secure/session/logout", "security_meaning": "Cookie input crosses the browser-to-server t...[rút gọn]}}
traces	evidence/traces/old_session_rejected.json	{"decision": "deny", "inspectors": {"session": {"authorization_decision": "deny", "cookie_name": "lab06_session", "cookie_present": true, "created_at": "2026-07-14T20:23:02.619546Z", "database_role": "user", "expires_at": "2026-07-14T20:53:02.619546Z", "hash_algorithm": "SHA-256", "last_seen_at": "2026-07-14T20:23:02.649900Z", "masked_session_id": "[REDACTED]", "reason": "inactive_session", "server_record_found": true, "session_active": false, "token_fingerprin...[rút gọn]}}
traces	evidence/traces/old_session_rejection.json	{"decision": "deny", "inspectors": {"session": {"authorization_decision": "deny", "cookie_name": "lab06_session", "cookie_present": true, "created_at": "2026-07-14T20:23:02.619546Z", "database_role": "user", "expires_at": "2026-07-14T20:53:02.619546Z", "hash_algorithm": "SHA-256", "last_seen_at": "2026-07-14T20:23:02.649900Z", "masked_session_id": "[REDACTED]", "reason": "inactive_session", "server_record_found": true, "session_active": false, "token_fingerprin...[rút gọn]}}
traces	evidence/traces/plain_admin_cookie_modified.json	{"decision": "allow", "mode": "plain", "route": "/vulnerable/plain/admin", "status": "completed", "steps": {"code_reference": "app.py:request_boundary", "description": "Flask reads only the cookies attached to this local request", "input_data": {"cookie_names": ["lab06_role", "lab06_username"]}, "layer": "HTTP Request", "output_data": {"mode": "plain", "route": "/vulnerable/plain/admin", "security_meaning": "Cookie input crosses the browser-to-server trust...[rút gọn]}}
traces	evidence/traces/plain_admin_denied.json	{"decision": "deny", "mode": "plain", "route": "/vulnerable/plain/admin", "status": "completed", "steps": {"code_reference": "app.py:request_boundary", "description": "Flask reads only the cookies attached to this local request", "input_data": {"cookie_names": ["lab06_role", "lab06_username"]}, "layer": "HTTP Request", "output_data": {"mode": "plain", "route": "/vulnerable/plain/admin", "security_meaning": "Cookie input crosses the browser-to-server trust...[rút gọn]}}
traces	evidence/traces/plain_cookie_login.json	{"decision": "cookie_issued", "mode": "plain", "route": "/login", "status": "completed", "steps": {"code_reference": "app.py:request_boundary", "description": "Flask reads only the cookies attached to this local request", "input_data": {"cookie_names": []}, "layer": "HTTP Request", "output_data": {"mode": "plain", "route": "/login", "security_meaning": "Cookie input crosses the browser-to-server trust boundary.", "status": "observed", "step_number": 1, "techn...[rút gọn]}}

Family	File	Trích đoạn
traces	evidence/traces/plain_cookie_modified.json	<pre>{ "decision": "allow", "mode": "plain", "route": "/vulnerable/plain/admin", "status": "completed", "steps": [{ "code_reference": "app.py:request_boundary", "description": "Flask reads only the cookies attached to this local request.", "input_data": { "cookie_names": ["lab06_role", "lab06_username"] }, "layer": "HTTP Request", "output_data": { "mode": "plain", "route": "/vulnerable/plain/admin", "security_meaning": "Cookie input crosses the browser-to-server trust boundary." } }] }</pre>
traces	evidence/traces/plain_login_student.json	<pre>{ "decision": "cookie_issued", "mode": "plain", "route": "/login", "status": "completed", "steps": [{ "code_reference": "app.py:request_boundary", "description": "Flask reads only the cookies attached to this local request.", "input_data": { "cookie_names": [] }, "layer": "HTTP Request", "output_data": { "mode": "plain", "route": "/login", "security_meaning": "Cookie input crosses the browser-to-server trust boundary.", "status": "observed", "step_number": 1, "technique": "technique" } }] }</pre>
traces	evidence/traces/server_session_admin_allowed.json	<pre>{ "decision": "allow", "inspectors": { "authorization": { "action": "view_admin", "allowed": true, "authentication_source": "server_session", "database_role": "admin", "database_role_checked": true, "policy": "active server session plus current database role must equal admin", "reason": "current_database_role_admin", "resource": "server_session_admin_page", "subject": "admin_lab", "submitted_role": null, "session": { "cookie_name": "lab06_session", "database_role": "admin" } } } }</pre>
traces	evidence/traces/server_session_admin_login.json	<pre>{ "decision": "session_created", "mode": "session", "route": "/login", "status": "completed", "steps": [{ "code_reference": "app.py:request_boundary", "description": "Flask reads only the cookies attached to this local request.", "input_data": { "cookie_names": [] }, "layer": "HTTP Request", "output_data": { "mode": "session", "route": "/login", "security_meaning": "Cookie input crosses the browser-to-server trust boundary.", "status": "observed", "step_number": 1, "technique": "technique" } }] }</pre>
traces	evidence/traces/server_session_logout.json	<pre>{ "decision": "logout", "mode": "server_session", "route": "/secure/session/logout", "status": "completed", "steps": [{ "code_reference": "app.py:request_boundary", "description": "Flask reads only the cookies attached to this local request.", "input_data": { "cookie_names": ["lab06_session"] }, "layer": "HTTP Request", "output_data": { "mode": "server_session", "route": "/secure/session/logout", "security_meaning": "Cookie input crosses the browser-to-server trust boundary." } }] }</pre>
traces	evidence/traces/server_session_rotated.json	<pre>{ "decision": "session_created", "mode": "session", "route": "/login", "status": "completed", "steps": [{ "code_reference": "app.py:request_boundary", "description": "Flask reads only the cookies attached to this local request.", "input_data": { "cookie_names": ["lab06_session"] }, "layer": "HTTP Request", "output_data": { "mode": "session", "route": "/login", "security_meaning": "Cookie input crosses the browser-to-server trust boundary.", "status": "observed", "step_number": 1, "technique": "technique" } }] }</pre>
traces	evidence/traces/server_session_student_admin_denied.json	<pre>{ "decision": "deny", "inspectors": { "authorization": { "action": "view_admin", "allowed": false, "authentication_source": "server_session", "database_role": "user", "database_role_checked": true, "policy": "active server session plus current database role must equal admin", "reason": "session_valid", "resource": "server_session_admin_page", "subject": "student", "submitted_role": null, "session": { "cookie_name": "lab06_session", "database_role": "user", "requested_resource": "server_session_admin_page" } } } }</pre>
traces	evidence/traces/server_session_student_login.json	<pre>{ "decision": "session_created", "mode": "session", "route": "/login", "status": "completed", "steps": [{ "code_reference": "app.py:request_boundary", "description": "Flask reads only the cookies attached to this local request.", "input_data": { "cookie_names": [] }, "layer": "HTTP Request", "output_data": { "mode": "session", "route": "/login", "security_meaning": "Cookie input crosses the browser-to-server trust boundary.", "status": "observed", "step_number": 1, "technique": "technique" } }] }</pre>
traces	evidence/traces/session_rotation.json	<pre>{ "decision": "session_created", "mode": "session", "route": "/login", "status": "completed", "steps": [{ "code_reference": "app.py:request_boundary", "description": "Flask reads only the cookies attached to this local request.", "input_data": { "cookie_names": ["lab06_session"] }, "layer": "HTTP Request", "output_data": { "mode": "session", "route": "/login", "security_meaning": "Cookie input crosses the browser-to-server trust boundary.", "status": "observed", "step_number": 1, "technique": "technique" } }] }</pre>
traces	evidence/traces/signed_cookie_invalid.json	<pre>{ "decision": "invalid", "inspectors": { "signature": { "confidentiality": false, "integrity": true, "payload_used": false, "reason": "signature_rejected", "signature_status": "invalid", "mode": "signed", "route": "/secure/signed/profile", "status": "completed", "steps": [{ "code_reference": "app.py:request_boundary", "description": "Flask reads only the cookies attached to this local request.", "input_data": { "cookie_names": ["lab06_signed_profile"] }, "layer": "HTTP Request" }] } } }</pre>
traces	evidence/traces/signed_cookie_login.json	<pre>{ "decision": "cookie_issued", "mode": "signed", "route": "/login", "status": "completed", "steps": [{ "code_reference": "app.py:request_boundary", "description": "Flask reads only the cookies attached to this local request.", "input_data": { "cookie_names": [] }, "layer": "HTTP Request", "output_data": { "mode": "signed", "route": "/login", "security_meaning": "Cookie input crosses the browser-to-server trust boundary.", "status": "observed", "step_number": 1, "technique": "technique" } }] }</pre>
traces	evidence/traces/signed_cookie_tampered.json	<pre>{ "decision": "invalid", "inspectors": { "signature": { "confidentiality": false, "integrity": true, "payload_used": false, "reason": "signature_rejected", "signature_status": "invalid", "mode": "signed", "route": "/secure/signed/profile", "status": "completed", "steps": [{ "code_reference": "app.py:request_boundary", "description": "Flask reads only the cookies attached to this local request.", "input_data": { "cookie_names": ["lab06_signed_profile"] }, "layer": "HTTP Request" }] } } }</pre>
traces	evidence/traces/signed_cookie_valid.json	<pre>{ "decision": "allow", "inspectors": { "authorization": { "authentication_source": "verified signed cookie", "database_role": "admin", "decision": "allow", "policy": "current database role must equal admin", "reason": "Role is read from SQLite after signature verification.", "requested_action": "view_admin", "requested_resource": "/secure/signed/admin", "subject": "admin_lab", "submitted_role": "admin", "signature": { "confidentiality": false, "integrity": true, "payload_used": false } } } }</pre>
traces	evidence/traces/student_admin_denied.json	<pre>{ "decision": "deny", "inspectors": { "authorization": { "action": "view_admin", "allowed": false, "authentication_source": "server_session", "database_role": "user", "database_role_checked": true, "policy": "active server session plus current database role must equal admin", "reason": "session_valid", "resource": "server_session_admin_page", "subject": "student", "submitted_role": null, "session": { "cookie_name": "lab06_session", "database_role": "user", "requested_resource": "server_session_admin_page" } } } }</pre>

Phụ lục B. Request và Response evidence

Evidence inventory

Family	File	Bytes	SHA-256
requests	evidence/requests/admin_allowed.json	329	05a3e89123a5bb07...
requests	evidence/requests/base64_admin_modified_cookie_request.txt	332	8ec14a2b35eeb02f...
requests	evidence/requests/base64_admin_user_cookie_request.txt	332	1882d09a0e33332c...
requests	evidence/requests/base64_cookie_login.json	347	486f56552e7073a3...
requests	evidence/requests/base64_modified.json	332	8ec14a2b35eeb02f...
requests	evidence/requests/base64_original.json	332	1882d09a0e33332c...
requests	evidence/requests/encrypted_cookie_valid_and_tampered.json	330	59d422f34a97ab74...
requests	evidence/requests/logout_invalidation.json	331	06d5b2be1685849c...
requests	evidence/requests/old_session_rejection.json	331	880205077a5603e0...
requests	evidence/requests/plain_admin_denied.json	331	3ecf706e79f399a2...
requests	evidence/requests/plain_admin_modified_cookie_request.txt	331	e80a0d7f6593181a...
requests	evidence/requests/plain_admin_user_cookie_request.txt	331	3ecf706e79f399a2...
requests	evidence/requests/plain_cookie_login.json	347	abf993c1917af1a2...
requests	evidence/requests/plain_cookie_modified.json	331	e80a0d7f6593181a...
requests	evidence/requests/plain_login_request.txt	347	abf993c1917af1a2...
requests	evidence/requests/server_session_admin_login.json	347	ff9e60c0c4f09d10...
requests	evidence/requests/server_session_student_login.json	347	9f56097cb6ba2689...
requests	evidence/requests/session_admin_request.txt	329	05a3e89123a5bb07...
requests	evidence/requests/session_logout_request.txt	331	06d5b2be1685849c...
requests	evidence/requests/session_rotation.json	347	0ef5f891f80ef176...
requests	evidence/requests/session_student_admin_request.txt	329	50dfd259b41cefb5...
requests	evidence/requests/signed_cookie_invalid.json	330	11f24970dc93e5bf...
requests	evidence/requests/signed_cookie_login.json	347	2597662ba702eb16...
requests	evidence/requests/signed_cookie_valid.json	328	001dddbbe6e6fb4b...
requests	evidence/requests/signed_tampered_request.txt	330	11f24970dc93e5bf...
requests	evidence/requests/signed_valid_request.txt	328	001dddbbe6e6fb4b...
requests	evidence/requests/student_admin_denied.json	329	50dfd259b41cefb5...
responses	evidence/responses/admin_allowed.json	359	8e48a77f8f2c7c28...
responses	evidence/responses/base64_admin_allowed_response.txt	275	335990efb7e6dc49...
responses	evidence/responses/base64_admin_denied_response.txt	273	940f27900cd39d2d...
responses	evidence/responses/base64_cookie_login.json	276	9d3cc76ebe2726cd...
responses	evidence/responses/base64_modified.json	275	335990efb7e6dc49...
responses	evidence/responses/base64_original.json	273	940f27900cd39d2d...
responses	evidence/responses/encrypted_cookie_valid_and_tampered.json	370	06b56a49eb901f4a...
responses	evidence/responses/logout_invalidation.json	328	fa9d10b85ed8dae...
responses	evidence/responses/old_session_rejection.json	360	fc994019b13d31c0...
responses	evidence/responses/plain_admin_allowed_response.txt	275	fa300613922731d7...
responses	evidence/responses/plain_admin_denied.json	273	fd44f019ba63f2e6...
responses	evidence/responses/plain_admin_denied_response.txt	273	fd44f019ba63f2e6...
responses	evidence/responses/plain_cookie_login.json	291	beed3ff622fe694...
responses	evidence/responses/plain_cookie_modified.json	275	fa300613922731d7...
responses	evidence/responses/server_session_admin_login.json	369	c8715f19a9abb67...
responses	evidence/responses/server_session_student_login.json	369	e6d186708fc5dc2d...
responses	evidence/responses/session_admin_allowed_response.txt	359	8e48a77f8f2c7c28...
responses	evidence/responses/session_logout_response.txt	328	fa9d10b85ed8dae...
responses	evidence/responses/session_rotation.json	369	905c5848ac75a614...
responses	evidence/responses/session_student_denied_response.txt	357	5434fdafbb03d9c3...
responses	evidence/responses/signed_cookie_invalid.json	315	9a26fcfe67b39812...
responses	evidence/responses/signed_cookie_login.json	275	da4d6c480e6b7cb9...
responses	evidence/responses/signed_cookie_valid.json	353	643e9d1f676c94be...
responses	evidence/responses/signed_tampered_response.txt	315	9a26fcfe67b39812...
responses	evidence/responses/signed_valid_response.txt	353	643e9d1f676c94be...

Family	File	Bytes	SHA-256
responses	evidence/responses/student_admin_denied.json	357	5434fdafbb03d9c3...

Trích đoạn evidence thật đã mask

Family	File	Trích đoạn
requests	evidence/requests/admin_allowed.json	{"content_length":0,"content_type":null,"form_field_names":[],"form_values":{},"host":"127.0.0.1:5006","method":"GET","observed_at":"2026-07-14T20:23:03.875895+00:00","path":"/secure/session/admin","query_string":"","scheme":"http","trace_id":"959504f05030b41ef0babf76"}
requests	evidence/requests/base64_admin_modified_cookie_request.txt	{"content_length":0,"content_type":null,"form_field_names":[],"form_values":{},"host":"127.0.0.1:5006","method":"GET","observed_at":"2026-07-14T20:23:01.483190+00:00","path":"/vulnerable/base64/admin","query_string":"","scheme":"http","trace_id":"cf8e8fa94d2c8a87cfdb9e1"}
requests	evidence/requests/base64_admin_user_cookie_request.txt	{"content_length":0,"content_type":null,"form_field_names":[],"form_values":{},"host":"127.0.0.1:5006","method":"GET","observed_at":"2026-07-14T20:23:01.461816+00:00","path":"/vulnerable/base64/admin","query_string":"","scheme":"http","trace_id":"087cb77f64d1a5b2069a9221"}
requests	evidence/requests/base64_cookie_login.json	{"content_length":49,"content_type":"application/x-www-form-urlencoded","form_field_names":[],"form_values":{},"host":"127.0.0.1:5006","method":"POST","observed_at":"2026-07-14T20:23:01.442563+00:00","path":"/login","query_string":"","scheme":"http","trace_id":"3c2d0912a00e73c8c5e1806e"}
requests	evidence/requests/base64_modified.json	{"content_length":0,"content_type":null,"form_field_names":[],"form_values":{},"host":"127.0.0.1:5006","method":"GET","observed_at":"2026-07-14T20:23:01.483190+00:00","path":"/vulnerable/base64/admin","query_string":"","scheme":"http","trace_id":"cf8e8fa94d2c8a87cfdb9e1"}
requests	evidence/requests/base64_original.json	{"content_length":0,"content_type":null,"form_field_names":[],"form_values":{},"host":"127.0.0.1:5006","method":"GET","observed_at":"2026-07-14T20:23:01.461816+00:00","path":"/vulnerable/base64/admin","query_string":"","scheme":"http","trace_id":"087cb77f64d1a5b2069a9221"}
requests	evidence/requests/encrypted_cookie_valid_and_tampered.json	{"content_length":0,"content_type":null,"form_field_names":[],"form_values":{},"host":"127.0.0.1:5006","method":"GET","observed_at":"2026-07-14T20:23:02.081317+00:00","path":"/secure/encrypted-demo","query_string":"","scheme":"http","trace_id":"a122a3d98992547bf27a7afc"}
requests	evidence/requests/logout_invalid.json	{"content_length":0,"content_type":null,"form_field_names":[],"form_values":{},"host":"127.0.0.1:5006","method":"POST","observed_at":"2026-07-14T20:23:03.257691+00:00","path":"/secure/session/logout","query_string":"","scheme":"http","trace_id":"0e4839a53210b3e11b407f8a"}
requests	evidence/requests/old_session_rejection.json	{"content_length":0,"content_type":null,"form_field_names":[],"form_values":{},"host":"127.0.0.1:5006","method":"GET","observed_at":"2026-07-14T20:23:03.246891+00:00","path":"/secure/session/profile","query_string":"","scheme":"http","trace_id":"7ea89c7bb70d9ed00290915d"}
requests	evidence/requests/plain_admin_denied.json	{"content_length":0,"content_type":null,"form_field_names":[],"form_values":{},"host":"127.0.0.1:5006","method":"GET","observed_at":"2026-07-14T20:23:00.779027+00:00","path":"/vulnerable/plain/admin","query_string":"","scheme":"http","trace_id":"6d32991cceac7a0329ab3718"}
requests	evidence/requests/plain_admin_modified_cookie_request.txt	{"content_length":0,"content_type":null,"form_field_names":[],"form_values":{},"host":"127.0.0.1:5006","method":"GET","observed_at":"2026-07-14T20:23:00.873929+00:00","path":"/vulnerable/plain/admin","query_string":"","scheme":"http","trace_id":"08e2634f3f3323a84e9d520"}
requests	evidence/requests/plain_admin_user_cookie_request.txt	{"content_length":0,"content_type":null,"form_field_names":[],"form_values":{},"host":"127.0.0.1:5006","method":"GET","observed_at":"2026-07-14T20:23:00.779027+00:00","path":"/vulnerable/plain/admin","query_string":"","scheme":"http","trace_id":"6d32991cceac7a0329ab3718"}
requests	evidence/requests/plain_cookie_login.json	{"content_length":48,"content_type":"application/x-www-form-urlencoded","form_field_names":[],"form_values":{},"host":"127.0.0.1:5006","method":"POST","observed_at":"2026-07-14T20:23:00.763629+00:00","path":"/login","query_string":"","scheme":"http","trace_id":"14a30b55a32a9de7a7bebe9"}
requests	evidence/requests/plain_cookie_modified.json	{"content_length":0,"content_type":null,"form_field_names":[],"form_values":{},"host":"127.0.0.1:5006","method":"GET","observed_at":"2026-07-14T20:23:00.873929+00:00","path":"/vulnerable/plain/admin","query_string":"","scheme":"http","trace_id":"08e2634f3f3323a84e9d520"}
requests	evidence/requests/plain_login_request.txt	{"content_length":48,"content_type":"application/x-www-form-urlencoded","form_field_names":[],"form_values":{},"host":"127.0.0.1:5006","method":"POST","observed_at":"2026-07-14T20:23:00.763629+00:00","path":"/login","query_string":"","scheme":"http","trace_id":"14a30b55a32a9de7a7bebe9"}
requests	evidence/requests/server_session_admin_login.json	{"content_length":53,"content_type":"application/x-www-form-urlencoded","form_field_names":[],"form_values":{},"host":"127.0.0.1:5006","method":"POST","observed_at":"2026-07-14T20:23:03.831754+00:00","path":"/login","query_string":"","scheme":"http","trace_id":"f1214dadb7574d2118202e69"}
requests	evidence/requests/server_session_student_login.json	{"content_length":50,"content_type":"application/x-www-form-urlencoded","form_field_names":[],"form_values":{},"host":"127.0.0.1:5006","method":"POST","observed_at":"2026-07-14T20:23:02.619546+00:00","path":"/login","query_string":"","scheme":"http","trace_id":"a7cfecd1bf20d1eae8510c45"}
requests	evidence/requests/session_admin_request.txt	{"content_length":0,"content_type":null,"form_field_names":[],"form_values":{},"host":"127.0.0.1:5006","method":"GET","observed_at":"2026-07-14T20:23:03.875895+00:00","path":"/secure/session/admin","query_string":"","scheme":"http","trace_id":"959504f05030b41ef0babf76"}
requests	evidence/requests/session_logout_request.txt	{"content_length":0,"content_type":null,"form_field_names":[],"form_values":{},"host":"127.0.0.1:5006","method":"POST","observed_at":"2026-07-14T20:23:03.257691+00:00","path":"/secure/session/logout","query_string":"","scheme":"http","trace_id":"0e4839a53210b3e11b407f8a"}
requests	evidence/requests/session_rotation.json	{"content_length":50,"content_type":"application/x-www-form-urlencoded","form_field_names":[],"form_values":{},"host":"127.0.0.1:5006","method":"POST","observed_at":"2026-07-14T20:23:03.231480+00:00","path":"/login","query_string":"","scheme":"http","trace_id":"203b442fe636c0187d871560"}
requests	evidence/requests/session_student_admin_request.txt	{"content_length":0,"content_type":null,"form_field_names":[],"form_values":{},"host":"127.0.0.1:5006","method":"GET","observed_at":"2026-07-14T20:23:02.658561+00:00","path":"/secure/session/admin","query_string":"","scheme":"http","trace_id":"40f58cf768a51ed2ac0cabd2"}
requests	evidence/requests/signed_cookie_invalid.json	{"content_length":0,"content_type":null,"form_field_names":[],"form_values":{},"host":"127.0.0.1:5006","method":"GET","observed_at":"2026-07-14T20:23:02.062061+00:00","path":"/secure/signed/profile","query_string":"","scheme":"http","trace_id":"636fa7a587223f83be5994f7"}
requests	evidence/requests/signed_cookie_login.json	{"content_length":52,"content_type":"application/x-www-form-urlencoded","form_field_names":[],"form_values":{},"host":"127.0.0.1:5006","method":"POST","observed_at":"2026-07-14T20:23:02.031511+00:00","path":"/login","query_string":"","scheme":"http","trace_id":"7907fb79eff09cbadd3d32a4"}
requests	evidence/requests/signed_cookie_valid.json	{"content_length":0,"content_type":null,"form_field_names":[],"form_values":{},"host":"127.0.0.1:5006","method":"GET","observed_at":"2026-07-14T20:23:02.045423+00:00","path":"/secure/signed/admin","query_string":"","scheme":"http","trace_id":"78365904d428593a977fb9ad"}

Family	File	Trích đoạn
requests	evidence/requests/signed_tampered_request.txt	{ "content_length": 0, "content_type": null, "form_field_names": [], "form_values": {}, "host": "127.0.0.1:5006", "method": "GET", "observed_at": "2026-07-14T20:23:02.062061+00:00", "path": "/secure/signed/profile", "query_string": "", "scheme": "http", "trace_id": "636fa7a587223f83be5994f7" }
requests	evidence/requests/signed_valid_request.txt	{ "content_length": 0, "content_type": null, "form_field_names": [], "form_values": {}, "host": "127.0.0.1:5006", "method": "GET", "observed_at": "2026-07-14T20:23:02.045423+00:00", "path": "/secure/signed/admin", "query_string": "", "scheme": "http", "trace_id": "78365904d428593a977fb9ad" }
requests	evidence/requests/student_admin_denied.json	{ "content_length": 0, "content_type": null, "form_field_names": [], "form_values": {}, "host": "127.0.0.1:5006", "method": "GET", "observed_at": "2026-07-14T20:23:02.658561+00:00", "path": "/secure/session/admin", "query_string": "", "scheme": "http", "trace_id": "40f58cf768a51ed2ac0cabd2" }
responses	evidence/responses/admin_allowed.json	{ "decision": "allow", "headers": { "Content-Type": "text/html; charset=utf-8", "X-Lab-Decision": "allow", "X-Lab-Role-Source": "database", "X-Lab-Session-Status": "session_valid", "X-Lab-Trace-ID": "959504f05030b41ef0babf76" }, "set_cookie_names": [], "status_code": 200, "trace_id": "959504f05030b41ef0babf76" }
responses	evidence/responses/base64_admin_allowed_response.txt	{ "decision": "allow", "headers": { "Content-Type": "text/html; charset=utf-8", "X-Lab-Decision": "allow", "X-Lab-Trace-ID": "cf8e8fa94d2c8a87cfdb9e1" }, "set_cookie_names": [], "status_code": 200, "trace_id": "cf8e8fa94d2c8a87cfdb9e1" }
responses	evidence/responses/base64_admin_denied_response.txt	{ "decision": "deny", "headers": { "Content-Type": "text/html; charset=utf-8", "X-Lab-Decision": "deny", "X-Lab-Trace-ID": "087cb77f64d1a5b2069a9221" }, "set_cookie_names": [], "status_code": 403, "trace_id": "087cb77f64d1a5b2069a9221" }
responses	evidence/responses/base64_cookie_login.json	{ "decision": "cookie_issued", "headers": { "Content-Type": "text/html; charset=utf-8", "Location": "/vulnerable/base64/profile", "set_cookie_names": ["lab06_profile_b64"], "status_code": 302, "trace_id": "3c2d0912a00e73c8c5e1806e" }
responses	evidence/responses/base64_modified.json	{ "decision": "allow", "headers": { "Content-Type": "text/html; charset=utf-8", "X-Lab-Decision": "allow", "X-Lab-Trace-ID": "cf8e8fa94d2c8a87cfdb9e1" }, "set_cookie_names": [], "status_code": 200, "trace_id": "cf8e8fa94d2c8a87cfdb9e1" }
responses	evidence/responses/base64_original.json	{ "decision": "deny", "headers": { "Content-Type": "text/html; charset=utf-8", "X-Lab-Decision": "deny", "X-Lab-Trace-ID": "087cb77f64d1a5b2069a9221" }, "set_cookie_names": [], "status_code": 403, "trace_id": "087cb77f64d1a5b2069a9221" }
responses	evidence/responses/encrypted_cookie_valid_and_tampered.json	{ "decision": "read_only_demo", "headers": { "Content-Type": "text/html; charset=utf-8", "X-Lab-Authorization-Use": "false", "X-Lab-Encryption-Status": "valid", "X-Lab-Trace-ID": "a122a3d98992547bf27a7afc" }, "set_cookie_names": ["lab06_encrypted_profile"], "status_code": 200, "trace_id": "a122a3d98992547bf27a7afc" }
responses	evidence/responses/logout_invalidation.json	{ "decision": "logout", "headers": { "Content-Type": "text/html; charset=utf-8", "X-Lab-Session-Status": "logout_invalidated_session", "X-Lab-Trace-ID": "0e4839a53210b3e11b407f8a" }, "set_cookie_names": ["lab06_session"], "status_code": 200, "trace_id": "0e4839a53210b3e11b407f8a" }
responses	evidence/responses/old_session_rejection.json	{ "decision": "deny", "headers": { "Content-Type": "text/html; charset=utf-8", "X-Lab-Decision": "deny", "X-Lab-Role-Source": "database", "X-Lab-Session-Status": "inactive_session", "X-Lab-Trace-ID": "7ea89c7bb70d9ed00290915d" }, "set_cookie_names": [], "status_code": 401, "trace_id": "7ea89c7bb70d9ed00290915d" }
responses	evidence/responses/plain_admin_allowed_response.txt	{ "decision": "allow", "headers": { "Content-Type": "text/html; charset=utf-8", "X-Lab-Decision": "allow", "X-Lab-Trace-ID": "08e2634f3f3323a84e9d520" }, "set_cookie_names": [], "status_code": 200, "trace_id": "08e2634f3f3323a84e9d520" }
responses	evidence/responses/plain_admin_denied.json	{ "decision": "deny", "headers": { "Content-Type": "text/html; charset=utf-8", "X-Lab-Decision": "deny", "X-Lab-Trace-ID": "6d32991ccec7a0329ab3718" }, "set_cookie_names": [], "status_code": 403, "trace_id": "6d32991ccec7a0329ab3718" }
responses	evidence/responses/plain_admin_denied_response.txt	{ "decision": "deny", "headers": { "Content-Type": "text/html; charset=utf-8", "X-Lab-Decision": "deny", "X-Lab-Trace-ID": "6d32991ccec7a0329ab3718" }, "set_cookie_names": [], "status_code": 403, "trace_id": "6d32991ccec7a0329ab3718" }
responses	evidence/responses/plain_cookie_login.json	{ "decision": "cookie_issued", "headers": { "Content-Type": "text/html; charset=utf-8", "Location": "/vulnerable/plain/profile", "set_cookie_names": ["lab06_username", "lab06_role"], "status_code": 302, "trace_id": "14a30b55a322a9de7a7bebe9" }
responses	evidence/responses/plain_cookie_modified.json	{ "decision": "allow", "headers": { "Content-Type": "text/html; charset=utf-8", "X-Lab-Decision": "allow", "X-Lab-Trace-ID": "08e2634f3f3323a84e9d520" }, "set_cookie_names": [], "status_code": 200, "trace_id": "08e2634f3f3323a84e9d520" }
responses	evidence/responses/server_session_admin_login.json	{ "decision": "session_created", "headers": { "Content-Type": "text/html; charset=utf-8", "Location": "/secure/session/profile", "X-Lab-Session-Status": "login_rotation", "X-Lab-Trace-ID": "f1214dadb7574d2118202e69" }, "set_cookie_names": ["lab06_session"], "status_code": 302, "trace_id": "f1214dadb7574d2118202e69" }
responses	evidence/responses/server_session_student_login.json	{ "decision": "session_created", "headers": { "Content-Type": "text/html; charset=utf-8", "Location": "/secure/session/profile", "X-Lab-Session-Status": "login_rotation", "X-Lab-Trace-ID": "a7cfecd1bf20d1eae8510c45" }, "set_cookie_names": ["lab06_session"], "status_code": 302, "trace_id": "a7cfecd1bf20d1eae8510c45" }
responses	evidence/responses/session_admin_allowed_response.txt	{ "decision": "allow", "headers": { "Content-Type": "text/html; charset=utf-8", "X-Lab-Decision": "allow", "X-Lab-Role-Source": "database", "X-Lab-Session-Status": "session_valid", "X-Lab-Trace-ID": "959504f05030b41ef0babf76" }, "set_cookie_names": [], "status_code": 200, "trace_id": "959504f05030b41ef0babf76" }
responses	evidence/responses/session_logout_response.txt	{ "decision": "logout", "headers": { "Content-Type": "text/html; charset=utf-8", "X-Lab-Session-Status": "logout_invalidated_session", "X-Lab-Trace-ID": "0e4839a53210b3e11b407f8a" }, "set_cookie_names": ["lab06_session"], "status_code": 200, "trace_id": "0e4839a53210b3e11b407f8a" }
responses	evidence/responses/session_rotation.json	{ "decision": "session_created", "headers": { "Content-Type": "text/html; charset=utf-8", "Location": "/secure/session/profile", "X-Lab-Session-Status": "login_rotation", "X-Lab-Trace-ID": "203b442fe636c0187d871560" }, "set_cookie_names": ["lab06_session"], "status_code": 302, "trace_id": "203b442fe636c0187d871560" }
responses	evidence/responses/session_student_denied_response.txt	{ "decision": "deny", "headers": { "Content-Type": "text/html; charset=utf-8", "X-Lab-Decision": "deny", "X-Lab-Role-Source": "database", "X-Lab-Session-Status": "session_valid", "X-Lab-Trace-ID": "40f58cf768a51ed2ac0cabd2" }, "set_cookie_names": [], "status_code": 403, "trace_id": "40f58cf768a51ed2ac0cabd2" }
responses	evidence/responses/signed_cookie_invalid.json	{ "decision": "deny", "headers": { "Content-Type": "text/html; charset=utf-8", "X-Lab-Decision": "deny", "X-Lab-Signature-Status": "invalid", "X-Lab-Trace-ID": "636fa7a587223f83be5994f7" }, "set_cookie_names": [], "status_code": 400, "trace_id": "636fa7a587223f83be5994f7" }
responses	evidence/responses/signed_cookie_login.json	{ "decision": "cookie_issued", "headers": { "Content-Type": "text/html; charset=utf-8", "Location": "/secure/signed/profile", "set_cookie_names": ["lab06_signed_profile"], "status_code": 302, "trace_id": "7907fb79ef09cbadd3d32a4" }

Family	File	Trích đoạn
responses	evidence/responses/signed_cookie_valid.json	{"decision": "allow", "headers": {"Content-Type": "text/html; charset=utf-8", "X-Lab-Decision": "allow", "X-Lab-Role-Source": "database", "X-Lab-Signature-Status": "valid", "X-Lab-Trace-ID": "78365904d428593a977fb9ad"}, "set_cookie_names": [], "status_code": 200, "trace_id": "78365904d428593a977fb9ad" }
responses	evidence/responses/signed_tampered_response.txt	{ "decision": "deny", "headers": { "Content-Type": "text/html; charset=utf-8", "X-Lab-Decision": "deny", "X-Lab-Role-Source": "database", "X-Lab-Signature-Status": "invalid", "X-Lab-Trace-ID": "636fa7a587223f83be5994f7" }, "set_cookie_names": [], "status_code": 400, "trace_id": "636fa7a587223f83be5994f7" }
responses	evidence/responses/signed_valid_response.txt	{ "decision": "allow", "headers": { "Content-Type": "text/html; charset=utf-8", "X-Lab-Decision": "allow", "X-Lab-Role-Source": "database", "X-Lab-Signature-Status": "valid", "X-Lab-Trace-ID": "78365904d428593a977fb9ad" }, "set_cookie_names": [], "status_code": 200, "trace_id": "78365904d428593a977fb9ad" }
responses	evidence/responses/student_admin_denied.json	{ "decision": "deny", "headers": { "Content-Type": "text/html; charset=utf-8", "X-Lab-Decision": "deny", "X-Lab-Role-Source": "database", "X-Lab-Signature-Status": "invalid", "X-Lab-Trace-ID": "40f58cf768a51ed2ac0cabd2" }, "set_cookie_names": [], "status_code": 403, "trace_id": "40f58cf768a51ed2ac0cabd2" }

Phụ lục C. Cookie, Session và Audit evidence

Evidence inventory

Family	File	Bytes	SHA-256
cookies	evidence/cookies/admin_allowed.json	238	e0f0c25cdc3ec430...
cookies	evidence/cookies/base64_cookie_login.json	503	b73986457bc2c0c8...
cookies	evidence/cookies/base64_cookie_observation.json	503	b73986457bc2c0c8...
cookies	evidence/cookies/base64_decoded_modified.json	280	054a4df2759640d1...
cookies	evidence/cookies/base64_decoded_original.json	277	e72114d135049226...
cookies	evidence/cookies/base64_modified.json	242	d8739ae61d53a9b6...
cookies	evidence/cookies/base64_original.json	243	9ed9a1d4b84585e4...
cookies	evidence/cookies/cookie_events.json	4	a5338d955b09046e...
cookies	evidence/cookies/encrypted_cookie_observation.json	994	f11548c5fcd3fee...
cookies	evidence/cookies/encrypted_cookie_valid_and_tampered.json	513	1c1e95c58a44ebdd...
cookies	evidence/cookies/logout_invalid.json	248	932c7b80fcd2ed00...
cookies	evidence/cookies/old_session_rejection.json	238	fae9fc948e220857...
cookies	evidence/cookies/plain_admin_denied.json	460	f86e09d975e2ed4d...
cookies	evidence/cookies/plain_cookie_diff.json	1108	5a41e33ae8c3cca3...
cookies	evidence/cookies/plain_cookie_login.json	959	3cd130e74638fdd8...
cookies	evidence/cookies/plain_cookie_modified.json	460	bad06843fb852088...
cookies	evidence/cookies/plain_cookie_observation.json	959	3cd130e74638fdd8...
cookies	evidence/cookies/server_session_admin_login.json	495	f8460f8f2e97d9ad...
cookies	evidence/cookies/server_session_cookie_observation.json	495	bbb999432695bca7...
cookies	evidence/cookies/server_session_student_login.json	495	bbb999432695bca7...
cookies	evidence/cookies/session_rotation.json	495	c775d2100f8978b6...
cookies	evidence/cookies/signed_cookie_invalid.json	245	16633e62c09d86af...
cookies	evidence/cookies/signed_cookie_login.json	507	62610174a47f627f...
cookies	evidence/cookies/signed_cookie_observation.json	507	62610174a47f627f...
cookies	evidence/cookies/signed_cookie_valid.json	245	0b4d4ba39e52bc50...
cookies	evidence/cookies/signed_cookie_verification.json	384	bd9b75d01fbd8c99...
cookies	evidence/cookies/student_admin_denied.json	238	f72ed501679537bb...
sessions	evidence/sessions/old_session_rejected.json	2486	8af65c791e05beb9...
sessions	evidence/sessions/server_sessions.json	1055	9c4a17926ea4d821...
sessions	evidence/sessions/session_created.json	1943	5989d879315ffdf7...
sessions	evidence/sessions/session_events.json	1227	79b78f3cae6b6a5e...
sessions	evidence/sessions/session_logout_invalidated.json	2133	ef8104e7333a5091...
sessions	evidence/sessions/session_rotated.json	1994	18aec66eddb2e801...
audit	evidence/audit/audit_logs.json	8222	7402e16ee14ab12a...

Trích đoạn evidence thật đã mask

Family	File	Trích đoạn
cookies	evidence/cookies/admin_allowed.json	[{"domain":"127.0.0.1","httponly":true,"masked_value":"Oosa...szNc","name":"lab06_session","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"e778d066d86e"}]
cookies	evidence/cookies/base64_cookie_login.json	[{"domain":"host-only","httponly":false,"masked_value":"eyJ1...ciJ9","max_age":null,"name":"lab06_profile_b64","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"3da9d76ee274"},{"domain":"127.0.0.1","httponly":false,"masked_value":"eyJ1...ciJ9","name":"lab06_profile_b64","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"3da9d76ee274"}]
cookies	evidence/cookies/base64_cookie_observation.json	[{"domain":"host-only","httponly":false,"masked_value":"eyJ1...ciJ9","max_age":null,"name":"lab06_profile_b64","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"3da9d76ee274"},{"domain":"127.0.0.1","httponly":false,"masked_value":"eyJ1...ciJ9","name":"lab06_profile_b64","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"3da9d76ee274"}]
cookies	evidence/cookies/base64_decoded_modified.json	{"algorithm":"URL-safe Base64","authorization_result":"allow","confidentiality":false,"decoded_json":{"user_name":"\\student\\","role":"admin"},"integrity":false,"parse_result":"decoded_without_integrity_check","role_extracted":"admin"}
cookies	evidence/cookies/base64_decoded_original.json	{"algorithm":"URL-safe Base64","authorization_result":"deny","confidentiality":false,"decoded_json":{"user_name":"\\student\\","role":"user"},"integrity":false,"parse_result":"decoded_without_integrity_check","role_extracted":"user"}
cookies	evidence/cookies/base64_modified.json	[{"domain":"127.0.0.1","httponly":false,"masked_value":"eyJ1...fQ==","name":"lab06_profile_b64","path":"/","samesite":null,"secure":false,"value_fingerprint":"8a28fd3eb98f"}]
cookies	evidence/cookies/base64_original.json	[{"domain":"127.0.0.1","httponly":false,"masked_value":"eyJ1...ciJ9","name":"lab06_profile_b64","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"3da9d76ee274"}]
cookies	evidence/cookies/cookie_events.json	[]
cookies	evidence/cookies/encrypted_cookie_observation.json	{"cookies":[{"domain":"host-only","httponly":true,"masked_value":"gAAA...tzQ=","max_age":null,"name":"lab06_encrypted_profile","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"30bf687a00c2"},{"domain":"127.0.0.1","httponly":true,"masked_value":"gAAA...tzQ=","name":"lab06_encrypted_profile","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"30bf687a00c2"}],"inspector":{"algorithm":"Fernet authenticated encryption","rút gọn"}}
cookies	evidence/cookies/encrypted_cookie_valid_and_tampered.json	[{"domain":"host-only","httponly":true,"masked_value":"gAAA...tzQ=","max_age":null,"name":"lab06_encrypted_profile","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"30bf687a00c2"},{"domain":"127.0.0.1","httponly":true,"masked_value":"gAAA...tzQ=","name":"lab06_encrypted_profile","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"30bf687a00c2"}]
cookies	evidence/cookies/logout_invalid.json	[{"domain":"host-only","httponly":true,"masked_value":"","max_age":"0","name":"lab06_session","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"e3b0c44298fc"}]
cookies	evidence/cookies/old_session_rejection.json	[{"domain":"127.0.0.1","httponly":false,"masked_value":"ocF5...nTsc","name":"lab06_session","path":"/","samesite":null,"secure":false,"value_fingerprint":"4fe41ab5064d"}]
cookies	evidence/cookies/plain_admin_denied.json	[{"domain":"127.0.0.1","httponly":false,"masked_value":"*****","name":"lab06_username","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"264c8c381bf1"},{"domain":"127.0.0.1","httponly":false,"masked_value":"*****","name":"lab06_role","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"04f8996da763"}]
cookies	evidence/cookies/plain_cookie_diff.json	[{"decision_after":"allow","decision_before":"deny","modified_manually":[{"domain":"127.0.0.1","httponly":false,"masked_value":"*****","name":"lab06_username","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"264c8c381bf1"},{"domain":"127.0.0.1","httponly":false,"masked_value":"*****","name":"lab06_role","path":"/","samesite":null,"secure":false,"value_fingerprint":"8c6976e5b541"}],"original":[{"domain":"127.0.0.1","httponly":false,"masked_value":"*****","name":"lab06_role","path":"/","samesite":null,"secure":false,"value_fingerprint":"8c6976e5b541"}]}]
cookies	evidence/cookies/plain_cookie_login.json	[{"domain":"host-only","httponly":false,"masked_value":"*****","max_age":null,"name":"lab06_username","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"264c8c381bf1"},{"domain":"host-only","httponly":false,"masked_value":"*****","max_age":null,"name":"lab06_role","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"04f8996da763"},{"domain":"127.0.0.1","httponly":false,"masked_value":"*****","name":"lab06_username","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"264c8c381bf1"}]
cookies	evidence/cookies/plain_cookie_modified.json	[{"domain":"127.0.0.1","httponly":false,"masked_value":"*****","name":"lab06_username","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"264c8c381bf1"},{"domain":"127.0.0.1","httponly":false,"masked_value":"*****","name":"lab06_role","path":"/","samesite":null,"secure":false,"value_fingerprint":"8c6976e5b541"}]
cookies	evidence/cookies/plain_cookie_observation.json	[{"domain":"host-only","httponly":false,"masked_value":"*****","max_age":null,"name":"lab06_username","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"264c8c381bf1"},{"domain":"host-only","httponly":false,"masked_value":"*****","max_age":null,"name":"lab06_role","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"04f8996da763"},{"domain":"127.0.0.1","httponly":false,"masked_value":"*****","name":"lab06_username","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"264c8c381bf1"}]
cookies	evidence/cookies/server_session_admin_login.json	[{"domain":"host-only","httponly":true,"masked_value":"Oosa...szNc","max_age":"1800","name":"lab06_session","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"e778d066d86e"},{"domain":"127.0.0.1","httponly":true,"masked_value":"Oosa...szNc","name":"lab06_session","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"e778d066d86e"}]
cookies	evidence/cookies/server_session_cookie_observation.json	[{"domain":"host-only","httponly":true,"masked_value":"ocF5...nTsc","max_age":"1800","name":"lab06_session","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"4fe41ab5064d"},{"domain":"127.0.0.1","httponly":true,"masked_value":"ocF5...nTsc","name":"lab06_session","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"4fe41ab5064d"}]
cookies	evidence/cookies/server_session_student_login.json	[{"domain":"host-only","httponly":true,"masked_value":"ocF5...nTsc","max_age":"1800","name":"lab06_session","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"4fe41ab5064d"},{"domain":"127.0.0.1","httponly":true,"masked_value":"ocF5...nTsc","name":"lab06_session","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"4fe41ab5064d"}]
cookies	evidence/cookies/session_rotation.json	[{"domain":"host-only","httponly":true,"masked_value":"9CXJ...Ebr0","max_age":"1800","name":"lab06_session","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"2daca90d0cde"},{"domain":"127.0.0.1","httponly":true,"masked_value":"9CXJ...Ebr0","name":"lab06_session","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"2daca90d0cde"}]
cookies	evidence/cookies/signed_cookie_invalid.json	[{"domain":"127.0.0.1","httponly":false,"masked_value":"eJw...9XbM","name":"lab06_signed_profile","path":"/","samesite":null,"secure":false,"value_fingerprint":"d0d2a9993df0"}]

Family	File	Trích đoạn
cookies	evidence/cookies/signed_cookie_login.json	[{"domain":"host-only","httponly":true,"masked_value":".ejw...9XbM","max_age":null,"name":"lab06_signed_profile","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"f7bce6694a5a"},{"domain":"127.0.0.1","httponly":true,"masked_value":".ejw...9XbM","name":"lab06_signed_profile","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"f7bce6694a5a"}]
cookies	evidence/cookies/signed_cookie_observation.json	[{"domain":"host-only","httponly":true,"masked_value":".ejw...9XbM","max_age":null,"name":"lab06_signed_profile","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"f7bce6694a5a"},{"domain":"127.0.0.1","httponly":true,"masked_value":".ejw...9XbM","name":"lab06_signed_profile","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"f7bce6694a5a"}]
cookies	evidence/cookies/signed_cookie_valid.json	[{"domain":"127.0.0.1","httponly":true,"masked_value":".ejw...9XbM","name":"lab06_signed_profile","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"f7bce6694a5a"}]
cookies	evidence/cookies/signed_cookie_verification.json	{"tampered":{"confidentiality":false,"integrity":true,"payload_used":false,"reason":"signature_rejected","signature_status":"invalid"},"valid":{"confidentiality":false,"integrity":true,"payload_used":true,"reason":"signature_verified","signature_status":"valid","signed_role":"admin"}}
cookies	evidence/cookies/student_admin_denied.json	[{"domain":"127.0.0.1","httponly":true,"masked_value":"ocF5...nTsc","name":"lab06_session","path":"/","samesite":"Lax","secure":false,"value_fingerprint":"4fe41ab5064d"}]
sessions	evidence/sessions/old_session_rejected.json	{"session_status":"inactive_session","trace":{"decision":"deny","inspectors":{"session":{"authorization_decision":"deny","cookie_name":"lab06_session","cookie_present":true,"created_at":"2026-07-14T20:23:02.619546Z","database_role":"user","expires_at":"2026-07-14T20:53:02.619546Z","hash_algorithm":"SHA-256","last_seen_at":"2026-07-14T20:23:02.649900Z","masked_session_id":"[REDACTED]","reason":"inactive_session","server_record_found":...[rút gọn]}}
sessions	evidence/sessions/server_sessions.json	[{"active":false,"created_at":"2026-07-14T20:23:02.619546Z","expires_at":"2026-07-14T20:53:02.619546Z","id":"16","last_seen_at":"2026-07-14T20:23:02.649900Z","revoked_at":"2026-07-14T20:23:03.232007Z","rotation_reason":"login_rotation","session_hash_fingerprint":"d0b840b95591","user_id":10},{"active":false,"created_at":"2026-07-14T20:23:03.232007Z","expires_at":"2026-07-14T20:53:03.232007Z","id":17,"last_seen_at":"2026-07-14T20:23:03.2...[rút gọn]}}
sessions	evidence/sessions/session_created.json	{"matching_events":[{"event_type":"server_session_created","id":24,"new_session_fingerprint":"4fe41ab5064d","old_session_fingerprint":null,"reason":"login_rotation","timestamp":"2026-07-14T20:23:02.619546Z","trace_id":"a7cfecd1bf20d1eae8510c45","user_id":10}],{"trace":{"decision":"session_created","mode":"session","route":"/login","status":"completed","steps":[{"code_reference":"app.py:request_boundary","description":"Flask reads only...[rút gọn]}}
sessions	evidence/sessions/session_events.json	[{"event_type":"server_session_created","id":24,"new_session_fingerprint":"4fe41ab5064d","old_session_fingerprint":null,"reason":"login_rotation","timestamp":"2026-07-14T20:23:02.619546Z","trace_id":"a7cfecd1bf20d1eae8510c45","user_id":10},{"event_type":"server_session_rotated","id":25,"new_session_fingerprint":"2daca90d0cde","old_session_fingerprint":"4fe41ab5064d","reason":"login_rotation","timestamp":"2026-07-14T20:23:03.232007Z","...[rút gọn]}}
sessions	evidence/sessions/session_logout_invalidated.json	{"matching_events":[{"event_type":"logout_invalidated_session","id":26,"new_session_fingerprint":null,"old_session_fingerprint":"2daca90d0cde","reason":"user_logout","timestamp":"2026-07-14T20:23:03.257691Z","trace_id":"0e4839a53210b3e11b407f8a","user_id":10}],{"trace":{"decision":"logout","mode":"server_session","route":"/secure/session/logout","status":"completed","steps":[{"code_reference":"app.py:request_boundary","description":"F...[rút gọn]}}
sessions	evidence/sessions/session_rotated.json	{"matching_events":[{"event_type":"server_session_rotated","id":25,"new_session_fingerprint":"2daca90d0cde","old_session_fingerprint":"4fe41ab5064d","reason":"login_rotation","timestamp":"2026-07-14T20:23:03.232007Z","trace_id":"203b442fe636c0187d871560","user_id":10}],{"trace":{"decision":"session_created","mode":"session","route":"/login","status":"completed","steps":[{"code_reference":"app.py:request_boundary","description":"Flask ...[rút gọn]}}
audit	evidence/audit/audit_logs.json	[{"action":"plain_cookie_issued","authorization_decision":"allow","cookie_name":"lab06_role","cookie_status":"issued","database_role":"user","id":87,"mode":"plain","reason":"fixed_plain_demo","route":"/login","submitted_role":"user","timestamp":"2026-07-14T20:23:00.764159Z","trace_id":"14a30b55a322a9de7a7bebe9","user_id":10,"username":"student"},{"action":"plain_admin_denied","authorization_decision":"deny","cookie_name":"lab06_role"...[rút gọn]}}

Phụ lục D. Source manifest

Source files đã đọc

File	SHA-256
README.md	f3de194fc12e81226451...
app.py	ba020ac1e7d6054166e2...
audit_service.py	2a3c117497dd945323ed...
auth_service.py	30f85d778d3ddf7d2ec6...
authorization_service.py	2256efe8970b1762cdf4...
base64_cookie_service.py	b26d6706ac7298322632...
config.py	696373d4c2f88f5f60ca...
cookie_service.py	8a0c5214f4415af76eff...
database.py	df4f4a1bbe6d81ae031e...
encrypted_cookie_service.py	6afce41b6d0742603119...
evidence/logs/requirements_review.txt	7121eac0a9fc7d87ebe9...
schema.sql	82bf4b5c2ab8d549cfa3...
server_session_service.py	65597f375822725d2f51...
signed_cookie_service.py	82a14f5cb88e1bbc0d13...
trace_models.py	532bafb919162f5a0f9e...
trace_service.py	640b63bd0b6209f8bdc9...

Phụ lục E. Lệnh kiểm chứng

```
pytest
pytest --cov=. --cov-report=term-missing
python scripts/run_runtime_smoke_test.py
python scripts/export_evidence.py
python scripts/generate_report.py
```